

Ataques Cibernéticos

Centro analítico de ameaças, vulnerabilidades, incidentes e resposta

320	Ativos
12.000	Alertas
680	Incidentes
18.000	Logins

Contexto

A AegisTech Industrial possui sistemas corporativos e industriais conectados. O crescimento da superfície de ataque aumentou alertas, vulnerabilidades e comportamentos suspeitos.

Objetivo

Priorizar riscos, reduzir tempos de detecção e contenção, proteger ativos críticos, fortalecer identidades e medir o impacto financeiro dos incidentes.

Indicadores recomendados

Indicador	Fórmula	Uso
Alertas críticos	Contagem de alertas críticos	Pressão operacional imediata.
Taxa de falso positivo	Falsos positivos / alertas	Qualidade das regras.
Incidentes abertos	Incidentes não encerrados	Backlog de resposta.
MTTD	Média de minutos até detectar	Velocidade de detecção.
MTTR	Média de minutos até conter	Velocidade de contenção.
Vulnerabilidades fora do SLA	Abertas além do prazo	Exposição técnica.
Taxa de clique	Cliques / mensagens	Risco humano.
Taxa de reporte	Reportes / mensagens	Maturidade do usuário.
Cobertura MFA	Usuários com MFA / usuários	Força de identidade.
Custo de incidentes	Soma das categorias de custo	Impacto financeiro.

Visões do dashboard

1. Centro Executivo

Alertas, incidentes, risco, MTTD, MTTR e perdas.

2. Ameaças

Tipos, origens, severidade e tendência temporal.

3. Incidentes

Status, resposta, ativos e registros comprometidos.

4. Vulnerabilidades

CVE, CVSS, SLA, criticidade e priorização.

5. Identidades

Logins suspeitos, MFA, países e sistemas.

6. Conscientização

Phishing, credenciais, reporte e treinamento.

7. Financeiro e LGPD

Custos, perdas e necessidade de notificação.

Perguntas de negócio

1. Quais ameaças crescem ao longo do tempo?
2. Quais alertas críticos permanecem sem tratamento?
3. Qual é a taxa de falso positivo por fonte?
4. Quais incidentes estão abertos e qual o impacto?
5. Como MTDD e MTTR variam por severidade?
6. Quais ativos concentram vulnerabilidades críticas?
7. Quais vulnerabilidades estão fora do SLA?
8. Quais usuários têm logins suspeitos e não utilizam MFA?
9. Quais áreas mais caem em phishing?
10. O treinamento melhora o reporte?
11. Qual é o custo total dos incidentes?
12. Quais casos exigem avaliação LGPD?

Modelo, qualidade e limitações

O modelo conecta áreas, usuários e ativos aos fatos de vulnerabilidades, alertas, incidentes, respostas, custos, logins, phishing e treinamentos. As chaves estrangeiras foram validadas no SQLite.

Limitações

Os dados são sintéticos e não incluem IP completo, payload, hash, evidência forense, regra SIEM, cadeia MITRE ATT&CK; detalhada, seguros ou custo reputacional. País de origem não identifica autoria.

Cuidados analíticos

Correlação entre país, usuário, treinamento e incidente não prova causalidade. Indicadores devem ser analisados com criticidade do ativo, contexto operacional e qualidade da detecção.

Plano de ação

Prioridade	Ação	Evidência	Responsável
Crítica	Conter incidentes críticos abertos	Severidade e status	SOC
Alta	Corrigir CVEs fora do SLA	CVSS, criticidade e idade	Infra
Alta	Aplicar MFA	Usuários sem MFA e logins suspeitos	IAM
Alta	Ajustar regras SIEM	Falso positivo elevado	SOC
Média	Reforçar treinamento	Clique e credenciais	GRC/RH
Média	Revisar resposta	MTTD e MTTR elevados	CSIRT